

BUUPP

Analyse d'impact relative à la protection des données (AIPD)

Traitement : mise en relation rémunérée avec scoring et segmentation — art. 35 RGPD

Responsable de traitement : Majelink (éditeur de la plateforme BUUPP) — RCS Pau 892 514 167 — 12
Impasse des Étriers, 64140 Lons

Chargé à la protection des données : dp.buupp@buupp.com

Version : 14/06/2026

Document de travail ancré sur le système en production (politique de confidentialité publiée, base de données, code source). Les arbitrages juridiques (bases légales, durées, désignation du DPO) doivent être validés par le DPO / le conseil juridique. Les champs marqués « [À COMPLÉTER] » requièrent une décision du responsable de traitement. Ce document ne constitue pas un avis juridique.

1. Faut-il une AIPD ? (critères CNIL / WP248)

Une AIPD est requise en cas de risque élevé probable. Le traitement central de BUUPP remplit plusieurs des 9 critères du CEPD (WP248) — deux suffisent :

- ✓ Évaluation / scoring : calcul du BUUPP Score.
- ✓ Croisement de données : segmentation multi-facettes (revenus, patrimoine, localisation, foyer...).
- ✓ Données hautement personnelles : revenus, patrimoine, projets, IBAN.
- ✓ Usage innovant : rémunération de la donnée à double consentement.
- ✓ Suivi systématique : journalisation des accès et des sollicitations.

Conclusion : AIPD requise. Le volet paiement fait l'objet d'une AIPD dédiée.

2. Description du traitement

- **Finalités** : mettre en relation des prospects consentants et des professionnels, en valorisant/segmentant les profils, avec rémunération du prospect.
- **Données** : identité (palier 1), profil enrichi (paliers 2-5 dont revenus/patrimoine), score dérivé, données de relation.
- **Acteurs** : prospects (personnes concernées), professionnels, personnels Majelink, sous-traitants (cf. registre).
- **Cycle de vie** : collecte (consentement par palier) → scoring/segmentation → sollicitation (double consentement) → pseudonymisation → révélation journalisée → rémunération → archivage/suppression.
- **Mesures existantes** : hébergement UE, chiffrement, RLS, pseudonymisation à la lecture, alias watermarqués, journal fail-closed + append-only, anti-fraude.

3. Nécessité et proportionnalité

- **Base légale** : contrat (mise en relation) ; consentement (paliers, sollicitations) ; obligation légale (fiscal) ; intérêt légitime (fraude). Balance d'intérêts du scoring à formaliser. [À COMPLÉTER]
- **Minimisation** : seuls les paliers nécessaires à l'objectif du pro sont autorisés/facturés ; paliers 2-5 facultatifs et révocables.
- **Qualité** : données saisies par le prospect ; téléphone vérifié OTP ; unicité anti-doublon.
- **Durées** : conformes au référentiel de conservation.
- **Information & droits** : politique de confidentialité, page DPO, page minimisation ; double consentement ; droits d'accès, rectification, effacement, opposition, portabilité.

4. Appréciation des risques pour les personnes

Trois événements redoutés (méthode CNIL) : accès illégitime, modification non désirée, disparition. Cotation gravité × vraisemblance à valider en atelier DPO.

Risque	Impact pour la personne	Mesures en place	Risque résiduel*
Accès illégitime (ré-identification, fuite IBAN/revenus)	Atteinte vie privée, démarchage abusif, risque financier	Pseudonymisation à la lecture ; alias watermarqués ; RLS ; chiffrement ; révélation gated + journalisée ; aucune carte stockée	Limité [à valider]
Détournement de finalité par un pro (extraction, revente)	Sollicitations hors cadre, perte de contrôle	Données non exportables ; consentement à usage unique ; watermark traçable ; journal inviolable ; alerte abus	Limité [à valider]

Risque	Impact pour la personne	Mesures en place	Risque résiduel*
Falsification d'une trace d'accès	Impossibilité de prouver l'accès	Journal append-only (trigger anti-UPDATE) + écriture fail-closed	Négligeable [à valider]
Profilage abusif (scoring) / décision défavorable	Exclusion d'opportunités, traitement inéquitable	Score non décisionnel à effet juridique ; transparence ; pas de catégorie sensible ; opposition/rectification	Limité [à valider]
Disparition / indisponibilité	Perte d'historique, de rémunération due	Hébergement managé (sauvegardes) ; séquestre des fonds	Limité [à valider]

* Cotation finale à arrêter avec le DPO (outil PIA CNIL). [À COMPLÉTER]

5. Plan d'action et validation

- Formaliser la balance d'intérêts du scoring (intérêt légitime).
- Arbitrer et automatiser les purges manquantes (prospection 3 ans, logs 12 mois).
- Tenir à jour les DPA des sous-traitants.
- Valider la cotation des risques (outil PIA CNIL) avec le DPO.

Rôle	Nom	Avis / décision	Date
Responsable de traitement	[À COMPLÉTER]		
DPO	[À COMPLÉTER]		